

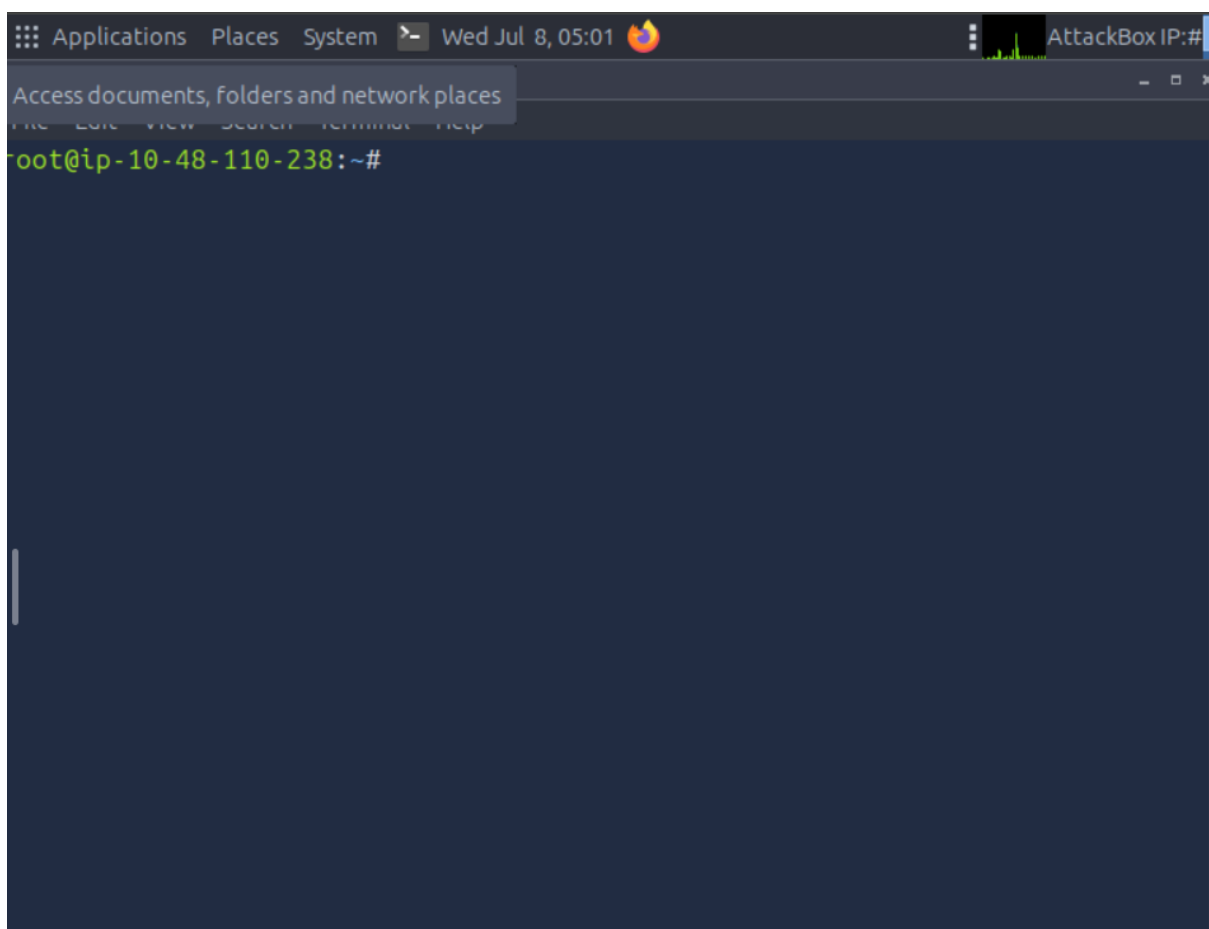
5.2-Operating System Security

Practical Example of OS Security

In one typical attack, the attacker seeks to gain access to a remote system. We can accomplish this attack by tricking the target into running a malicious file or by obtaining a username and a password. We will focus on the latter. After discovering a username, we will try to “guess” the password; furthermore, we will try to escalate our privileges to a system administrator. This account is called **root** on Android, Apple, and Linux systems. While, on MS Windows systems, this account is called **administrator**. The **accounts root and administrator have complete unrestricted access to a system.**

In this task, we will try to hack into a Linux system. We assume that you have never used a Linux system before, and we will explain accordingly.

On the AttackBox, start the terminal by clicking on the terminal icon shown in the image above. You will be writing all the commands you need on the terminal shown below.



We will cover the following Linux commands and explain them throughout this task.

- **whoami**
- **ssh USERNAME@MACHINE_IP**
- **ls**
- **cat FILENAME**
- **history**

We were hired to check the security of a certain company. When we visited our client's office, we noticed a sticky note with two words: sammie and dragon on one of the screens. Let's see if **dragon is Sammie's password** on the lab machine 10.48.191.90. From the AttackBox's terminal, we will try to log in to Sammie's account by executing **ssh sammie@10.48.191.90**. The remote system will ask you to provide sammie's password, **dragon**.

The first time we connect to a server over SSH, we will get a warning about the server's authenticity and SSH key. We need to answer "Are you sure you want to continue connecting (yes/no)?" with yes.

Please note the following when entering the password over SSH. When you log in via SSH, you won't see that you are typing the password. In other words, **when you are typing the SSH password, you won't see stars, dots, or any indicator on the screen that the password is being typed**. However, the system still receives the password you are entering.

The interaction on the AttackBox's terminal is shown below.

In Machine_ip(10.48.191.90) you give your IP Address.

Yes print

```
root@ip-10-48-123-217:~# ssh sammie@10.48.191.90
The authenticity of host '10.48.191.90 (10.48.191.90)' can't be established.
ED25519 key fingerprint is SHA256:5yx4LzFv6wwFb2fzSnMznIor0XX0qdQsr2SmFJZNpXg.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.48.191.90' (ED25519) to the list of known hosts.
```

```
sammie@10.48.191.90's password:
Welcome to Ubuntu 20.04.4 LTS (GNU/Linux 5.4.0-100-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Tue  1 Mar 13:20:32 UTC 2022

System load:  0.03               Processes:            216
Usage of /:   51.8% of 6.53GB    Users logged in:     1
Memory usage: 17%               IPv4 address for ens33: 10.48.191.90
Swap usage:   0%

 * Super-optimized for small spaces - read how we shrank the memory
   footprint of MicroK8s to make it the smallest full K8s around.

https://ubuntu.com/blog/microk8s-memory-optimisation

updates can be applied immediately.
```

```
Last login: Wed Mar  2 08:00:25 2022 from 10.20.30.1
```

Amazing! It worked! Let's confirm that we are logged in as Sammie using the `whoami` (*who am I?*) command, which should return `sammie`.

```
sammie@ip-10-48-191-90:~$ whoami
sammie
```

To list the files in the current directory, we can use `ls`, short for *list*. This command will show all the files in the current directory unless they are hidden.

```
sammie@ip-10-48-191-90:~$ ls
country.txt  draft.md  icon.png  password.txt  profile.jpg
```

If you want to display the contents of any text file, you can use the command `cat FILENAME`, short for *concatenate*. This command will print the contents of the file on the screen.

```
sammie@ip-10-48-191-90:~$ cat draft.md
# Operating System Security

Reusing passwords means that your password for other sites becomes exposed if one service is hacked.
```

In our brief introduction to Linux, the last command that we will cover is history. This command prints the commands used by the user.

We have learned about two other usernames that can access the attached machine. They are:

- johnny
- linda

We know that both of these users have little regard for cybersecurity best practices. We can use several ways to guess the passwords for these two users. Here we list two approaches:

- If you are **not** logged in as sammie or any other user, you can use ssh johnny@10.48.191.90 and manually try one password after the next to see which password works for johnny.
- If you are logged in as sammie or any other user, you can use su - johnny and manually try one password after the next to see which password works for johnny.

```
sammie@ip-10-48-191-90:~$ ssh johnny@10.48.191.90
The authenticity of host '10.48.191.90 (10.48.191.90)' can't be established.
ECDSA key fingerprint is SHA256:D/6GXGtBmUaQIuyGouIEggaqNQtnX9X1DcV2bxQ0/F0.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.48.191.90' (ECDSA) to the list of known hosts
```

Rank	Password
1	123456
2	123456789
3	qwerty
4	password
5	111111
6	12345678
7	abc123

1)

Based on the top 7 passwords, let's try to find Johnny's password. What is the password for the user johnny ?

2) Once you are logged in as Johnny, use the command history to check the commands that Johnny has typed. We expect Johnny to have mistakenly typed the root password instead of a command. What is the root password?

```
johnny@ip-10-48-191-90:~$ history
1  ls
2  vi notes.txt
3  mv notes.txt coffee.txt
4  vi cheese.txt
5  wget -c https://upload.wikimedia.org/wikipedia/commons/a/af/Tux.png
6  ls
7  su - root
8  happyHack!NG
9  su - root
10 whoami
11 ls
12 cat coffee.txt
13 whoami
14 pwd
15 date
16 exit
17 history
```

happyHack!NG

3) While logged in as Johnny, use the command `su - root` to switch to the root account. Display the contents of the file `flag.txt` in the root directory. What is the content of the file?

```
johnny@ip-10-48-191-90:~$ su - root
Password:
root@ip-10-48-191-90:~# ls
flag.txt  snap
root@ip-10-48-191-90:~# cat flag.txt
A) THM{YouGotRoot}
```

Password is happyHack!NG for su – root

And flag is THM{YouGotRoot}